

Security Fundamentals

- Topics covered:
 - Key Security Concepts
 - Common Attacks
 - Passwords/Multi-Factor Authentication (MFA)
 - Authentication, Authorization, Accounting (AAA)
 - Security Program Elements

Key Security Concepts

Why Security?

The purpose of security in an enterprise is to protect its **information and systems**.

The foundation of security is the **CIA Triad**:

C — Confidentiality:

Confidentiality means that only authorized users should be able to access data.

- Some information is public and can be accessed by anyone, such as information on a company website.
- Some information is secret and should only be accessed by specific people.
- There are also different degrees of secrecy between these levels.

I — Integrity:

Integrity means that data should not be tampered with or modified by unauthorized users.

Data should remain correct and authentic, rather than being modified by an attacker.

A — Availability:

Availability means that the enterprise network and systems should be operational and accessible to authorized users.

For example:

1. Staff should be able to access the internal resources required to perform their duties.
2. The company's website should be up and running and available to customers.

Computer Networks - CCNA

Attackers can threaten the **confidentiality, integrity, and availability** of an enterprise's systems and information.

Fundamental Security Concepts

Vulnerability:

A vulnerability is **any potential weakness** that can compromise the CIA of a system or information.

A potential weakness by itself is not necessarily a problem.

For example, the windows of a house are potential weaknesses, but houses continue to have windows.

Exploit:

An exploit is something that can potentially be used to **exploit a vulnerability**.

Something that can potentially be used as an exploit is not necessarily a problem on its own.

For example, a rock can exploit the weakness of a window and be used to enter a house, but rocks are not problems on their own.

Threat:

A threat is the **potential of a vulnerability to be exploited**.

The window and rock example connects the concepts:

- Window → Vulnerability
- Rock → Exploit
- Robber wanting to use the rock to break the window → Threat

A relevant security example is a **hacker exploiting a vulnerability in a system**.

Mitigation Technique:

A mitigation technique is something that can **protect against threats**.

Different mitigation techniques depend on the threat being defended against.

They should be implemented wherever a vulnerability can be exploited, including:

1. Client devices
2. Servers
3. Switches
4. Routers

Computer Networks - CCNA

Mitigation techniques can also prevent unauthorized people from getting physical access to devices, such as keeping devices in a **secure rack behind a secure door**.

No System Is Perfectly Secure:

Systems can be:

- More secure
- Less secure

But there are **no guarantees in security**.

For example, even if malware detection is implemented on a network firewall and the best antivirus software is installed on client PCs, the chance of the PCs becoming infected with malware is never 0.



Common Attacks

Common Types of Attacks?

Common attacks are **threats that can potentially exploit vulnerabilities** to compromise the:

- Confidentiality
- Integrity
- Availability

of an enterprise's systems and information.

There are many more potential attacks, but these are some of the main attack categories.

1. Denial-of-Service (DoS) Attack

A Denial-of-Service (DoS) attack threatens **the availability** of a system.

Therefore, it targets: A — Availability in the CIA Triad

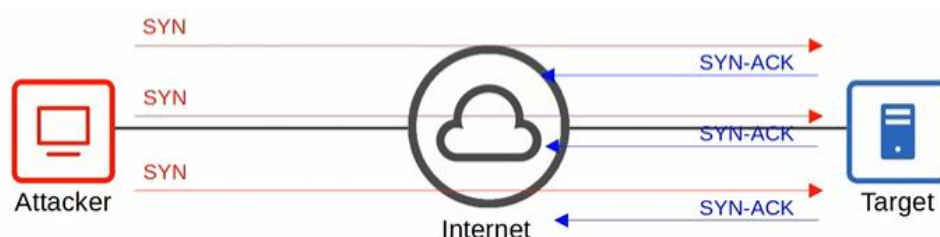
There are many types of DoS attacks. One common type is the TCP SYN flood, which exploits the TCP three-way handshake.

TCP Three-Way Handshake: SYN → SYN-ACK → ACK

In a TCP SYN flood:

1. The attacker sends countless TCP SYN messages to the target.
2. The target sends a SYN-ACK in response to each SYN.
3. The attacker never sends the final ACK.
4. The target waits for the final ACK.
5. The incomplete connections fill the target's TCP connection table.

Attack Flow



Computer Networks - CCNA

For every SYN received:

1. The target puts an entry in its TCP connection table.
2. The target sends a SYN-ACK.
3. The target waits for the ACK.
4. The ACK never comes.

The attacker continues sending SYN messages, and the target continues sending SYN-ACK messages.

Eventually, the target's TCP connection table becomes full.

The incomplete connections will eventually **time out and be removed**, but the attacker continues sending SYN messages to fill the table again.

When the target reaches the maximum number of TCP connections it can maintain, it can no longer make legitimate TCP connections.

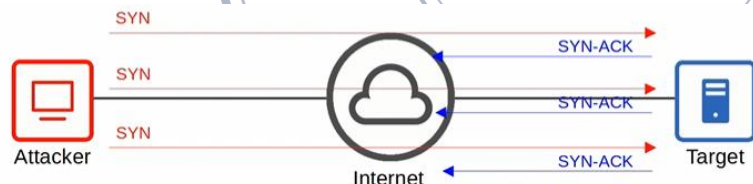
This achieves the denial-of-service.

SYN-ACK and IP Spoofing:

The SYN-ACK arrows do not reach the attacker because the attacker likely **spoofs their IP address**.

IP spoofing means using a fake IP address.

Therefore, the SYN-ACK messages do not return to the actual attacker.



Spoof attacks are discussed after DoS attacks.

2. Distributed Denial-of-Service (DDoS)

A DoS attack is usually not performed **by a single attacker**.

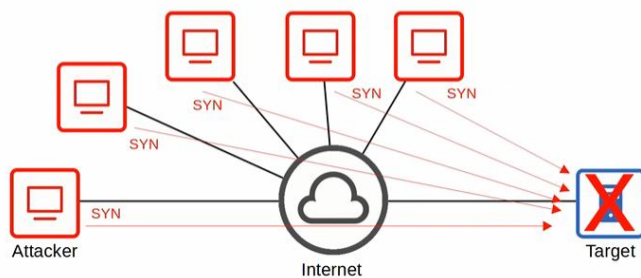
A more powerful type is a Distributed Denial-of-Service (DDoS) attack.

In a DDoS attack:

1. The attacker infects many target computers with malware.
2. The infected computers are used together to initiate a DoS attack.
3. The attack can be a TCP SYN flood.
4. The group of infected computers is called a botnet.

Computer Networks - CCNA

DDoS Structure



The attacker can infect the PCs through separate attacks. Then, all the infected PCs together flood the target with TCP SYN messages.

As a result, the target server is no longer able to respond to **legitimate TCP connection requests**.

3. Spoofing Attacks

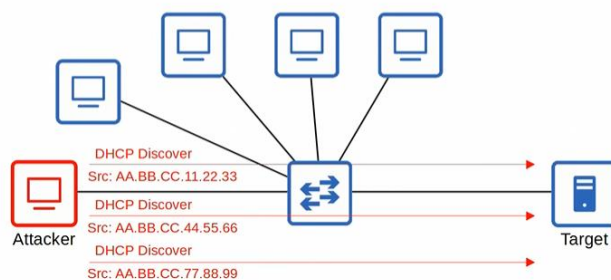
To spoof an address means to use a **fake source address**, such as a fake IP address or MAC address.

Spoofing is not a single type of attack. There are numerous attacks that involve spoofing.

One example is a **DHCP exhaustion attack**. It is similar to a TCP SYN flood attack.

DHCP Exhaustion Attack:

In a DHCP exhaustion attack, the attacker uses **spoofed MAC addresses** to flood the target with **DHCP Discover messages**.



The attacker:

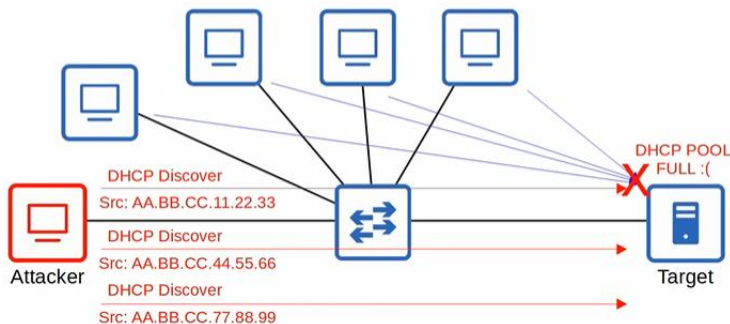
1. Sends a DHCP Discover message with a fake source MAC address.
2. Sends another DHCP Discover with a different fake source MAC address.
3. Continues sending Discover messages with different fake source MAC addresses.
4. Sends them at a very quick pace.

Computer Networks - CCNA

The server responds to each Discover with a DHCP Offer. While it is offering an IP address, it will not assign that address to other devices.

As a result, the server's DHCP pool becomes full.

For example, if the server has 250 IP addresses available to lease to clients, they can all be taken by the attacker.



When other PCs send DHCP Discover messages to obtain IP addresses, the server cannot give them their IP addresses because its DHCP pool is full.

This results in a denial-of-service to other devices.

Spoofing and Other Attack Types:

The DHCP exhaustion attack is both:

- A **spoofing attack**, because spoofed MAC addresses are used.
- A **DoS attack**, because it results in a denial-of-service.

The previous TCP SYN flood also used spoofed source IP addresses, so it is also a spoofing attack. Therefore, some attack types are connected and related, rather than being completely separate.

The DHCP exhaustion attack attacks:

Availability — A of the CIA Triad

However, not all spoofing attacks are DoS attacks.

Another type of spoofing attack can target:

- Confidentiality
- Integrity

rather than availability.

Computer Networks - CCNA

4. Reflection/Amplification Attacks

In a reflection attack, the attacker sends traffic to a reflector and spoofs the source address of the packets using the target's IP address.

The reflector, such as a **DNS server**, then sends its reply to the target's IP address.

If the amount of traffic is large enough, this can result in a denial-of-service to the target.

Amplification Attacks:

A more powerful form of reflection attack is an amplification attack.

A reflection attack becomes an amplification attack when:

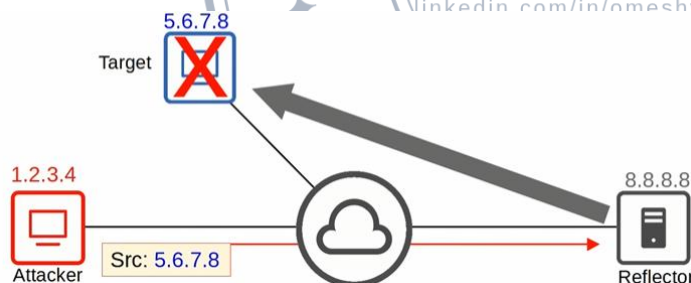
- The amount of traffic sent by the attacker is small.
- It triggers a **large amount of traffic** from the reflector to the target.

This large amount of traffic can trigger a **denial-of-service**.

Reflection/Amplification Example

The attacker's actual IP address is 1.2.3.4.

The attacker uses the spoofed source IP address 5.6.7.8 to send a message to the server 8.8.8.8, which becomes the reflector.



The attacker's message causes the reflector to send a large amount of traffic to the target, resulting in a denial-of-service.

There are DNS and NTP vulnerabilities that can be exploited for amplification attacks like this

5. Man-in-the-Middle Attack

In a man-in-the-middle (MITM) attack, the attacker places **themselves between the source and destination.**

The attacker can:

- Eavesdrop on communications
- Modify traffic before it reaches the destination

A common example is ARP spoofing, also known as ARP poisoning.

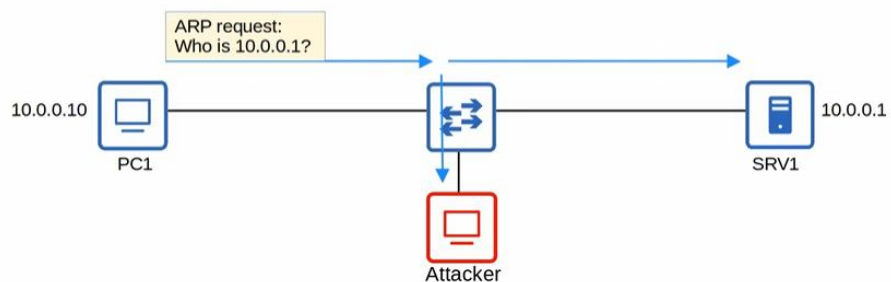
ARP spoofing is another type of spoofing attack.

ARP Spoofing / ARP Poisoning:

In an ARP spoofing attack, a host sends an ARP request asking for the MAC address of another device.

In this example:

PC1 asks for the MAC address of 10.0.0.1.



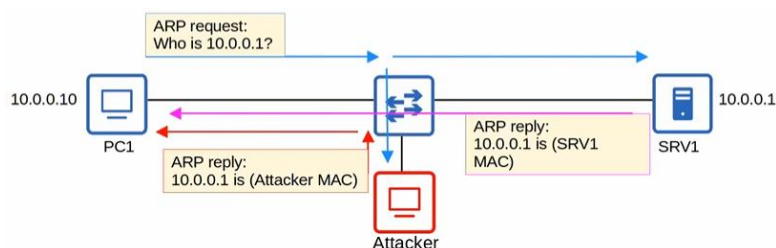
Because ARP request messages are broadcast, the switch floods the frame.

Therefore, both SRV1 and the attacker receive the ARP request.

ARP Spoofing Attack

The legitimate target of the ARP request, SRV1, sends an ARP reply informing PC1 of SRV1's MAC address.

But the attacker waits briefly and then sends another ARP reply after the legitimate replier.

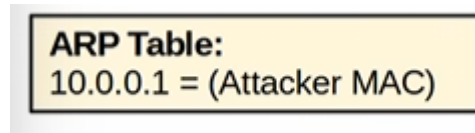


Computer Networks - CCNA

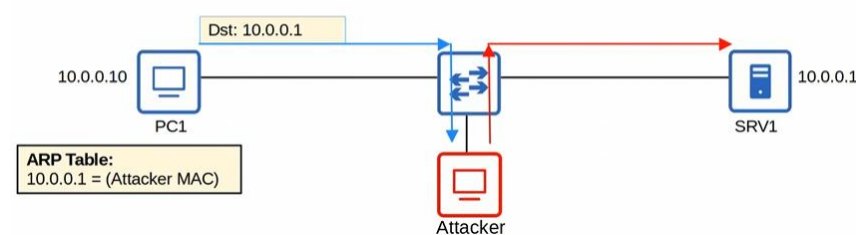
If the attacker's ARP reply arrives last, it overwrites the legitimate ARP entry in PC1's ARP table.

ARP Table After the Attack

PC1's ARP table now contains the attacker's MAC address for **10.0.0.1**, instead of SRV1's MAC address.



Therefore, when PC1 tries to send traffic to SRV1:



The traffic is forwarded to the attacker instead.

What the Attacker Can Do

Once the traffic is forwarded to the attacker, the attacker can:

1. Inspect the messages.
2. Read their contents.
3. Forward them to SRV1.
4. Modify the messages before forwarding them to SRV1.

CIA Impact of ARP Spoofing

Unlike the DHCP exhaustion example, this attack does not primarily target availability.

It compromises:

Confidentiality — C:

Confidentiality is compromised because an unauthorized user, the attacker, has access to the communications between PC1 and SRV1.

Integrity — I:

Integrity is compromised because the unauthorized user can modify the data before it reaches the destination.

Computer Networks - CCNA

6. Reconnaissance Attacks

Reconnaissance attacks are not attacks themselves. They are used to **gather information about a target** that can be used for a future attack.

The information is often publicly available, so it is not really an attack itself because the information is not confidential.

An **NSLOOKUP** can be used to learn the IP address of a site.

```
C:\Users\user>nslookup jeremysitlab.com
Server: UnKnown
Address: 192.168.0.1

Non-authoritative answer:
Name:    jeremysitlab.com
Address: 162.241.216.233
```

From the IP address, an attacker can probe for open ports, which are potential vulnerabilities.

A **WHOIS query** can be used to learn information such as:

- Email addresses
- Phone numbers
- Physical addresses

Once contact information is known, social engineering attacks can be carried out to threaten the target enterprise. [linkedin.com/in/omeshwar23](https://www.linkedin.com/in/omeshwar23)

Computer Networks - CCNA

7. Malware

Malware means **malicious software**. It refers to various harmful programs that can infect a computer.

Three types discussed are: Viruses, Worms, Trojan horses

Viruses:

A virus is malware that infects other software, called a host program.

The virus spreads as the software is:

- Shared by users
- Downloaded from malicious websites

After infecting a device, a virus can perform harmful actions, such as corrupting or modifying files on the target computer.

Worms:

Worms are different from viruses because they do not require a host program.

They are standalone malware and can spread on their own, without user interaction.

The spread of worms from device to device can:

- Congest the network
- Cause additional harm if the worm contains a payload

A payload is other malicious code within the worm.

Trojan Horse:

A Trojan horse is harmful software disguised as legitimate software.

Trojan horses spread through user interaction, such as:

- Opening email attachments
- Downloading a file from the Internet

Important Malware Point:

These malware types are defined mostly by how the malware infects a system and how it spreads, rather than by the attacks they carry out after infecting the system.

The malware types discussed can exploit various vulnerabilities to threaten any part of the CIA triad of the target device.

These three are only a few large categories because there are many types of malware.

Computer Networks - CCNA

8. Social Engineering Attacks

Social engineering is a very dangerous category of attack.

Social engineering attacks target **the most vulnerable part of any system: people.**

No matter how many security features are configured on routers, switches, firewalls, servers, PCs, etc., people are always a vulnerability that can be exploited.

Social engineering attacks use psychological manipulation to make the target:

- Reveal confidential information, or
- Perform an action the attacker tells them to do.

There are various types of social engineering attacks.

Phishing:

Phishing involves fraudulent emails that appear to come from a legitimate business, such as:

- Amazon
- A bank
- A credit card company

These emails contain links to a fraudulent website that seems legitimate.

For example, the website may look identical to the real login page of a bank.

The user is told to log in to the fraudulent website, providing their login credentials to the attacker.

Spear phishing is a more targeted type of phishing.

Instead of mass emails being sent to anybody, emails may be sent specifically to employees of a particular company.

Whaling is phishing targeted at high-profile individuals, such as a company president.

Vishing, or voice phishing, is phishing performed over the phone.

The attacker could pretend to be from:

- The target's bank
- Another department in the company

The attacker may attempt to convince the target to reveal their current password or other information.

Computer Networks - CCNA

Smishing, or SMS phishing, is phishing performed using SMS text messages sent to the target's cell phone.

A watering hole attack compromises websites that the target victim frequently visits.

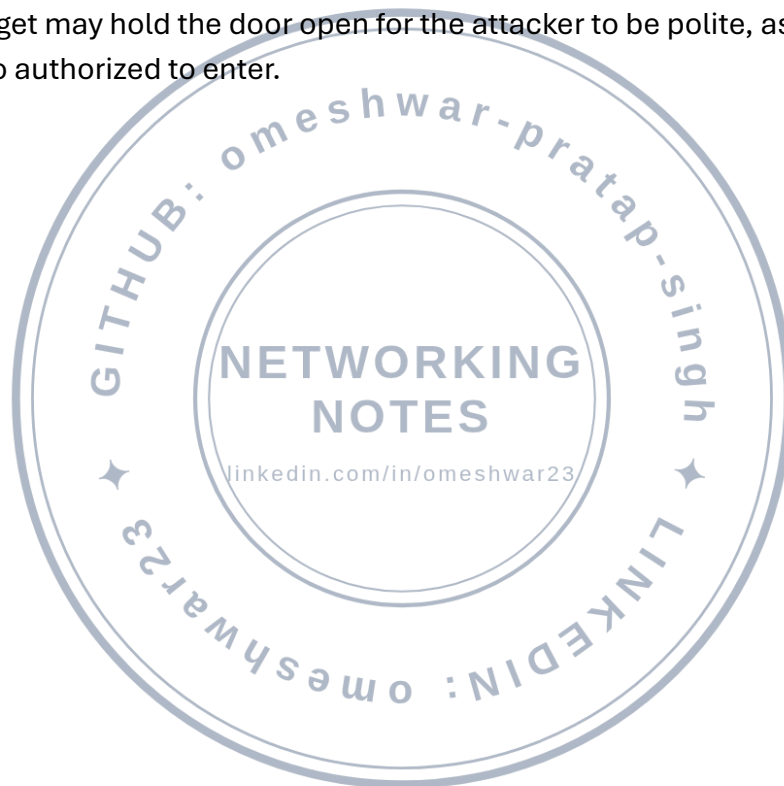
If a malicious link is placed on a website the target trusts, the target might not hesitate to click it.

The attack takes advantage of the user's trust in a website they frequently visit.

Tailgating attacks involve entering restricted, secure areas by simply walking in behind an authorized person as they enter.

Companies with restricted areas have rules against this.

However, a target may hold the door open for the attacker to be polite, assuming the attacker is also authorized to enter.



Passwords/Multi-Factor Authentication (MFA)

Password-Related Attacks

Most systems use a **username and password combination** to authenticate users.

The username is often simple and easy to guess, such as the user's email address.

Therefore, the strength and secrecy of the password is relied on to provide the necessary security.

Attackers can learn a user's password through multiple methods.

Guessing:

An attacker could simply guess the password.

Successfully guessing a password should be extremely rare, but it is a possibility.

Dictionary Attack:

A dictionary attack uses a program that goes through a dictionary containing common words and passwords.

The program tries each one, hoping to find the correct password.

Brute Force Attack:

A brute force attack involves trying every possible combination of:

- Letters
- Numbers
- Special characters

to find the target's password.

It requires a very powerful computer.

If the password is sufficiently strong, the chances of a brute force attack working are very low because it takes so much time.

Strong Passwords:

Strong passwords should contain:

1. At least 8 characters
2. Preferably more than 8 characters
3. A mix of uppercase and lowercase letters

Computer Networks - CCNA

4. A mixture of letters and numbers
5. One or more special characters, such as ? or !
6. The password should be changed regularly

The more characters a password has, the harder it is to brute-force.

Most enterprises enforce rules like these for employees, and these rules are also recommended when creating personal passwords.

Multi-Factor Authentication (MFA)

No matter how secure a password is, there is still a chance that it gets into the hands of an attacker. This is why multi-factor authentication (MFA) is becoming more widespread.

Multi-factor authentication requires providing **more than just a username and password** to prove your identity.

It usually involves providing two of the following factors, in which case it is called two-factor authentication (2FA).

Three Authentication Factors

Factor	Meaning	Examples
Something you know	Information known by you	Username and password, PIN
Something you have	Something in your possession	Phone notification using an authenticator app, badge that is scanned
Something you are	Unique characteristics about you	Face scan, palm scan, fingerprint scan, retina scan

Requiring multiple authentication factors greatly increases security.

Even if an attacker learns the target's password, they will not be able to log in to the target's account.

Computer Networks - CCNA

Digital Certificates

Another form of authentication uses digital certificates.

Digital certificates are used to **prove the identity of the holder** of the certificate.

They are mainly, but not exclusively, used for websites to verify that the website being accessed is legitimate.

Certificate Process:

An entity that wants a certificate, such as a company with a website, sends a **CSR (Certificate Signing Request)** to a **CA (Certificate Authority)**.

When accessing a website, modern browsers display a symbol indicating that the website is secure and has a valid certificate.

The certificate can be inspected through that symbol.

This allows you to know that the website being accessed is really [jeremysitlab.com](https://www.jeremysitlab.com), rather than a fake website pretending to be [jeremysitlab.com](https://www.jeremysitlab.com).



Authentication, Authorization, Accounting (AAA)

AAA Framework

Authentication is one part of an important framework for the CCNA.

AAA stands for:

- Authentication
- Authorization
- Accounting

AAA is a framework for **controlling and monitoring users of a computer system**, such as a network.

Authentication:

Authentication is the process of verifying a user's identity.

When a user logs in, ideally using multi-factor authentication, that is authentication.

Authorization:

Authorization is the process of granting the user appropriate access and permissions.

For example, granting access to some files and services while restricting access to other files and services is authorization.

Accounting:

Accounting is the process of recording the user's activities on the system.

Examples include:

- Logging when a user makes a change to a file.
- Recording when a user logs in or logs out.

AAA Component Purpose:

Authentication Verifies who the user is

Authorization Determines what access the user has

Accounting Records what the user does

Computer Networks - CCNA

AAA Servers and Protocols:

Enterprises typically use a AAA server to provide AAA services.

ISE (Identity Services Engine) is Cisco's AAA server.

AAA servers typically support two AAA protocols:

RADIUS

- Open standard protocol
- Uses UDP ports 1812 and 1813

TACACS+

- Cisco proprietary protocol
- Uses TCP port 49

Protocol	Type	Transport	Ports
RADIUS	Open standard	UDP	1812, 1813
TACACS+	Cisco proprietary	TCP	49

For the CCNA, remember the protocol names and their ports, and especially the differences between authentication, authorization, and accounting.

linkedin.com/in/omeshwar23

Security Program Elements

What Is Security Program Elements?

A security program is an enterprise's set of **security policies and procedures**.

For the CCNA, the following security program elements need to be understood.

1. User Awareness Programs

User awareness programs are designed to make employees aware of **potential security threats and risks**.

Not all employees are cybersecurity experts. For example, someone working in the HR department may not be aware of all the cybersecurity threats facing the company.

User awareness programs help make those employees aware of these threats.

Example:

A company might send false phishing emails that ask employees to click a link and sign in with their login credentials.

The emails are harmless. Employees who are tricked by the false emails are informed that the activity was part of a user awareness program and that they should be more careful about phishing emails.

2. User Training Programs

User training programs are more formal than user awareness programs.

They can include dedicated training sessions that educate users about:

- Corporate security policies
- How to create strong passwords
- How to avoid potential threats

Training should occur:

- When employees enter the company
- At regular intervals during the year

Computer Networks - CCNA

3. Physical Access Control

Physical access control is another essential element of a security program.

It protects equipment and data from potential attackers by allowing only authorized users into protected areas, such as:

- Network closets
- Data center floors

Access should not only be restricted to people outside the organization.

Even within the company, access should be limited to employees who need access.

4. Multifactor Physical Access

Multifactor locks can protect access to restricted areas.

For example, a door may require users to:

1. Swipe a badge
2. Scan their fingerprint

5. Badge Systems

Badge systems are very flexible, and the permissions granted to a badge can easily be changed.

For example, permissions can be easily removed when an employee leaves the company, whether or not the employee returns the badge.

This allows for strict, centralized control of who is authorized to enter where.